

MIDTECH S.A.

Política de Seguridad de la Información

Documento:	PSI-MIDTECH-2025-v2.1
Versión:	2.1
Fecha:	Enero 2025
Clasificación:	USO INTERNO
Aprobado por:	Dirección General
Próxima revisión:	Enero 2026

Biología · Diagnóstico · Servicios Hospitalarios · Bio Supplies

1. Información general de la organización

MIDTECH S.A. es una empresa del sector salud con actividad principal en biotecnología e industria farmacéutica, con sede central en Zaragoza y oficinas en Madrid y Barcelona.

Dato	Descripción
Nombre legal	MIDTECH S.A.
Sede principal	Zaragoza (también Madrid y Barcelona)
Sector	Biotecnología e industria farmacéutica
Líneas de negocio	Biopharma, Diagnóstico, Servicios Hospitalarios, Bio Supplies
Clientes	Hospitales públicos y privados, laboratorios clínicos, empresas pharma/biotech
Facturación anual	1.524 millones de euros (2025)
Empleados	~120 por sede; 780 en sede central
Tecnologías críticas	Separación industrial de proteínas plasmáticas (inmunoglobulinas, albúmina, factores de coagulación)

2. Objeto y alcance

La presente Política de Seguridad de la Información (PSI) establece los principios, responsabilidades y controles básicos que deben regir el tratamiento de la información en MIDTECH S.A. con el objetivo de proteger la confidencialidad, integridad y disponibilidad de los activos de información.

Esta política aplica a:

- Todos los empleados de MIDTECH S.A. en cualquiera de sus sedes.
- Sistemas de información corporativos, equipos de trabajo y dispositivos móviles.
- Aplicaciones de gestión clínica, ERP y sistemas de laboratorio (LIMS).
- Proveedores y terceros con acceso a los sistemas de MIDTECH S.A.

3. Control de acceso

3.1 Gestión de usuarios

El acceso a los sistemas de información de MIDTECH S.A. se otorga en función del principio de mínimo privilegio. Todo acceso debe estar previamente autorizado por el responsable del área correspondiente.

- Los perfiles de acceso se revisan cuando hay cambios de rol o cese del empleado.
- Las cuentas de usuario inactivas durante más de 90 días se desactivan automáticamente.
- Los accesos de administrador se gestionan de forma separada a las cuentas de usuario estándar.

3.2 Política de contraseñas

Todos los usuarios deben cumplir con los siguientes requisitos de contraseña:

- Longitud mínima de 8 caracteres.
- Combinación de letras mayúsculas, minúsculas y números.
- Cambio obligatorio cada 180 días.

- No se permite reutilizar las últimas 5 contraseñas.

Nota: No se ha implantado autenticación multifactor (MFA) de forma generalizada. Su adopción está en evaluación para el próximo ejercicio presupuestario.

3.3 Acceso remoto

El acceso remoto a los sistemas corporativos se realiza mediante VPN corporativa. Los usuarios que accedan de forma remota deben utilizar equipos corporativos o dispositivos aprobados por el departamento de TI.

4. Seguridad física y del entorno

Las instalaciones de MIDTECH S.A. cuentan con control de acceso físico mediante tarjeta de proximidad. El centro de datos de Zaragoza dispone de sistemas de detección de incendios y climatización controlada.

- El acceso al Centro de Proceso de Datos (CPD) está restringido al personal de TI autorizado.
- Las visitas externas deben ser acompañadas en todo momento por personal de la empresa.
- Los equipos portátiles corporativos disponen de cifrado de disco completo (BitLocker).

Limitación identificada: Las oficinas de Madrid y Barcelona no disponen de CPD propio. Los servidores locales de esas sedes no están bajo el mismo nivel de control físico que la sede central. No existe un procedimiento documentado de inspección periódica de instalaciones físicas.

5. Gestión de activos

MIDTECH S.A. mantiene un inventario de activos de hardware y software gestionado por el departamento de TI. El inventario se actualiza de forma manual cuando se produce una alta o baja de equipo.

- Cada activo tiene asignado un responsable (propietario del activo).
- Los equipos en desuso son formateados antes de su retirada o reutilización.

Limitación identificada: El inventario no incluye activos de software de terceros (SaaS) utilizados por los departamentos de forma autónoma. No existe una clasificación formal de activos por nivel de criticidad o clasificación de la información.

6. Cifrado y protección de datos

6.1 Cifrado en reposo

Las bases de datos de producción que contienen datos clínicos y de investigación disponen de cifrado en reposo mediante AES-256. Los equipos portátiles están cifrados con BitLocker.

6.2 Transferencia de información

Para el intercambio de información con clientes y proveedores se utilizan el correo electrónico corporativo y la plataforma de intercambio de ficheros habilitada por TI.

Limitación identificada: No existe una política documentada sobre el cifrado de la información en tránsito. No se especifican los protocolos mínimos aceptables (TLS 1.2 o superior) para las

comunicaciones internas y externas. El uso de protocolos seguros depende de la configuración por defecto de cada aplicación.

7. Gestión de incidentes de seguridad

MIDTECH S.A. dispone de un procedimiento básico de notificación de incidentes de seguridad. Cualquier empleado que detecte un incidente debe notificarlo al departamento de TI a través del correo de soporte (soporte.ti@midtech.es) o por teléfono.

7.1 Proceso de notificación

1. Detección y notificación al departamento de TI.
2. Registro del incidente en el sistema de tickets.
3. Análisis y clasificación por parte del equipo de TI.
4. Aplicación de medidas de contención.
5. Cierre del ticket y comunicación al usuario afectado.

Limitaciones identificadas: No existe una clasificación formal de incidentes por severidad (crítico, alto, medio, bajo). El procedimiento no contempla de forma explícita los plazos de notificación a la Autoridad de Control en caso de brecha de datos personales (72 horas según el GDPR). No hay un equipo de respuesta a incidentes (CSIRT) formalmente constituido. No se realizan ejercicios de simulación o pruebas del procedimiento.

8. Continuidad del negocio y copias de seguridad

MIDTECH S.A. realiza copias de seguridad diarias de los servidores de producción. Las copias se almacenan en un servidor de backup ubicado en la misma sala del CPD de Zaragoza.

- Frecuencia de backup: diaria (incremental) y semanal (completa).
- Retención: 30 días para backups diarios, 6 meses para backups semanales.

Limitaciones identificadas: No existe un Plan de Continuidad de Negocio (BCP) ni un Plan de Recuperación ante Desastres (DRP) formalmente documentados. Las copias de seguridad se almacenan en la misma ubicación física que los sistemas de producción, sin copia offsite. No se realizan pruebas de restauración de forma periódica.

9. Relación con proveedores y terceros

MIDTECH S.A. trabaja con proveedores externos que pueden tener acceso a sistemas o datos de la organización. Los accesos de proveedores se gestionan a través del departamento de TI.

Limitaciones identificadas: No existe un proceso formal de evaluación de seguridad de proveedores antes de concederles acceso. Los contratos con proveedores no incluyen de forma sistemática cláusulas de seguridad de la información ni requisitos de notificación de incidentes. No se realizan auditorías periódicas de los accesos de terceros.

10. Concienciación y formación en seguridad

MIDTECH S.A. realiza una sesión de formación en seguridad de la información para los nuevos empleados en el momento de su incorporación. El material cubre los aspectos básicos de la política de contraseñas, uso del correo electrónico y clasificación de la información.

Limitaciones identificadas: No existe un plan de formación continua en ciberseguridad para el personal existente. No se realizan ejercicios de phishing simulado. No hay registro de qué empleados han completado la formación inicial.

11. Protección de datos personales (GDPR)

MIDTECH S.A. trata datos personales de pacientes, empleados y clientes en el marco de su actividad. La empresa ha designado un Responsable de Privacidad interno para supervisar el cumplimiento normativo.

- Se mantiene un registro básico de actividades de tratamiento para los procesos principales.
- Los datos de pacientes se tratan de acuerdo con el principio de confidencialidad médica.

Limitaciones identificadas: No se ha designado un Delegado de Protección de Datos (DPO) externo o independiente. El registro de actividades de tratamiento no está completo para todos los procesos. No existe una política documentada de retención y eliminación de datos personales. No se han realizado Evaluaciones de Impacto de Protección de Datos (EIPD) para los tratamientos de alto riesgo. Los formularios de consentimiento informado no se han revisado desde 2022.

12. Revisión y cumplimiento

La presente política será revisada anualmente o cuando se produzcan cambios organizativos significativos que afecten a la seguridad de la información.

Limitación identificada: No existe constancia documental de que la última revisión de esta política se haya completado formalmente. No hay un proceso de auditoría interna de cumplimiento de la política. No se han definido métricas o indicadores de seguimiento del nivel de seguridad.

Anexo A: Resumen de controles implementados

Área de control	Estado	Referencia	Observaciones
Control de acceso por mínimo privilegio	Implementado	ISO A.9.1.2	Sin revisión periódica formal
Política de contraseñas	Parcial	ISO A.9.4.3	Sin MFA. Longitud mínima de 8 chars insuficiente
Autenticación multifactor (MFA)	No implementado	ISO A.9.4.2	En evaluación presupuestaria
Cifrado en reposo (BBDD producción)	Implementado	ISO A.10.1.1	AES-256
Cifrado en tránsito	No documentado	ISO A.10.1.1 / GDPR Art. 32	Sin política formal ni protocolos mínimos
Seguridad física CPD Zaragoza	Implementado	ISO A.11.1	Sedes secundarias sin nivel equivalente
Inventario de activos	Parcial	ISO A.8.1	Sin SaaS de terceros ni clasificación de criticidad
Gestión de incidentes	Parcial	ISO A.16.1 / GDPR Art. 33	Sin severidad. Sin plazo 72h GDPR. Sin CSIRT
Copias de seguridad	Parcial	ISO A.12.3	Sin copia offsite. Sin pruebas de restauración
Plan de Continuidad (BCP/DRP)	No implementado	ISO A.17.1	No existe documentación
Gestión de proveedores	No implementado	ISO A.15.1 / GDPR Art. 28	Sin cláusulas de seguridad en contratos
Formación continua en seguridad	Parcial	ISO A.7.2.2	Solo onboarding. Sin plan continuo ni registros
Delegado de Protección de Datos	No implementado	GDPR Art. 37	Sin DPO designado
Evaluación de Impacto (EIPD)	No implementado	GDPR Art. 35	Sin ninguna EIPD realizada
Registro actividades de tratamiento	Parcial	GDPR Art. 30	Incompleto para todos los procesos
Revisión periódica de la política	No documentado	ISO A.18.2	Sin constancia de última revisión